Healthcare IAM - Workforce Termination Risk Assessment

Risk assessment — 1.0

This assessment evaluates the risk of incomplete employee deprovisioning across Microsoft Entra ID and Keycloak within the Care Access Navigator healthcare environment.

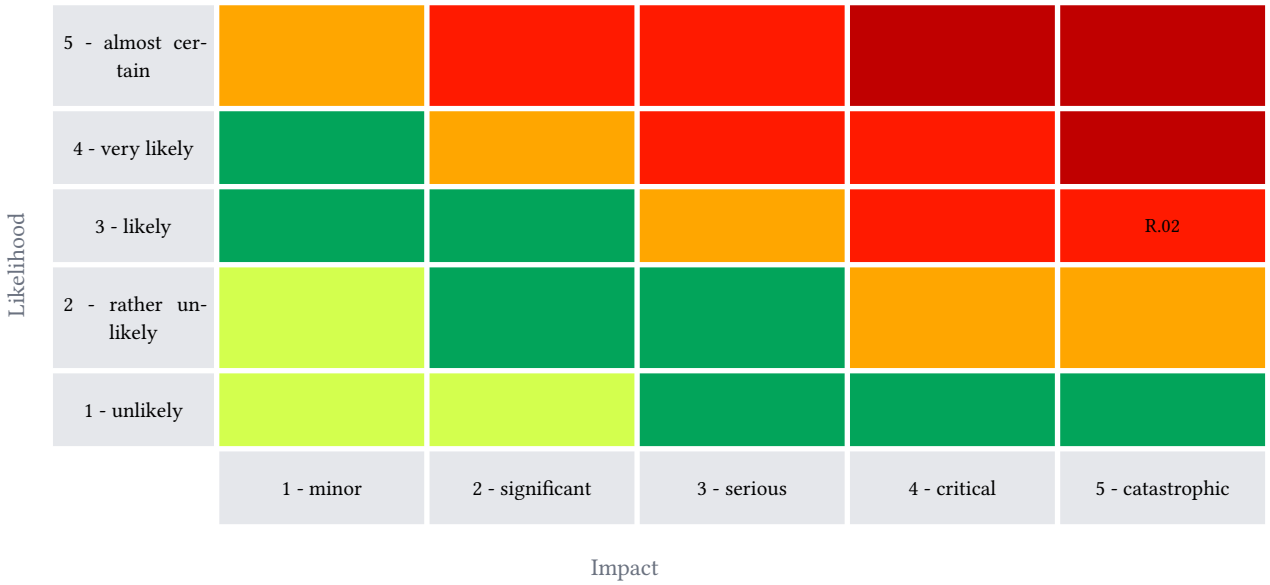
The assessment uses the existing R02 risk and Jeevan Smith's termination evidence (TERM-2026-0301) to examine account deactivation, role revocation, session management, residual risk, and HIPAA-aligned workforce termination controls.

Domain	Care Access Navigator - IAM & GRC
Perimeter	Care Access Navigator - IAM & GRC/Mock EHR - Workforce Access Governance
Risk matrix	5x5 ISO-27005
Status	In progress
Authors	-
Reviewers	-
ETA / Due	- — -

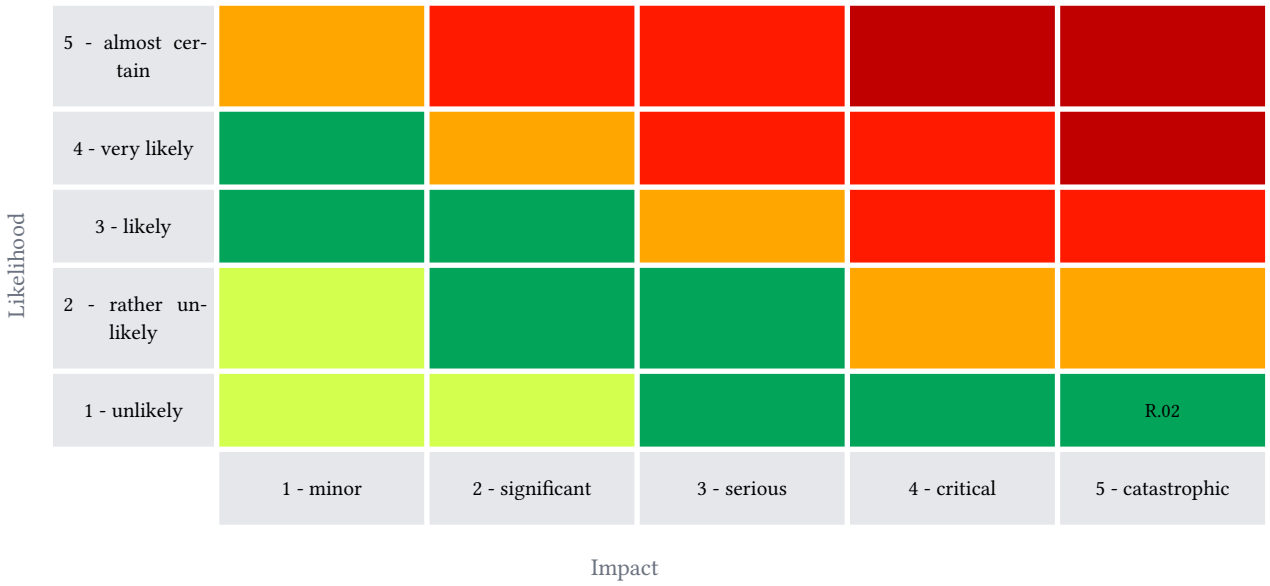
Generated at 2026-11-03 20:24:31 UTC
Document ID `dcf0b5f0-1ca0-448c-b8bd-a05b4f7b7dbc`

Risk matrix

Current risk



Residual risk



Scenario summary

Ref.	Name	Description	Current	Residual	Treatment
R.02	Incomplete Leaver Deprovisioning Across Entra ID and Keycloak	A terminated healthcare employee may retain access to the Mock EHR application because disabling their Microsoft Entra ID account does not automatically disable the corresponding federated Keycloak account. During Jeevan Smith's termination (TERM-2026-0301), Entra ID access was disabled, but the Keycloak account required additional manual deactivation. This creates a potential risk of unauthorized access through stale accounts or existing sessions. The risk will be evaluated using the project's existing R02 risk assessment, JML evidence, and HIPAA-aligned workforce termination controls.	4 - high	2 - low	Mitigate

Risk scenarios

1 scenarios.

R.02 — Incomplete Leaver Deprovisioning Across Entra ID and Keycloak

Description	A terminated healthcare employee may retain access to the Mock EHR application because disabling their Microsoft Entra ID account does not automatically disable the corresponding federated Keycloak account. During Jeevan Smith's termination (TERM-2026-0301), Entra ID access was disabled, but the Keycloak account required additional manual deactivation. This creates a potential risk of unauthorized access through stale accounts or existing sessions. The risk will be evaluated using the project's existing R02 risk assessment, JML evidence, and HIPAA-aligned workforce termination controls.
Assets	Mock EHR Application
Existing controls	Workforce Termination and Access Revocation
Current level	4 - high
Extra controls	Automated Keycloak Leaver Deprovisioning
Residual level	2 - low
Strength of knowledge	--
Treatment	Mitigate